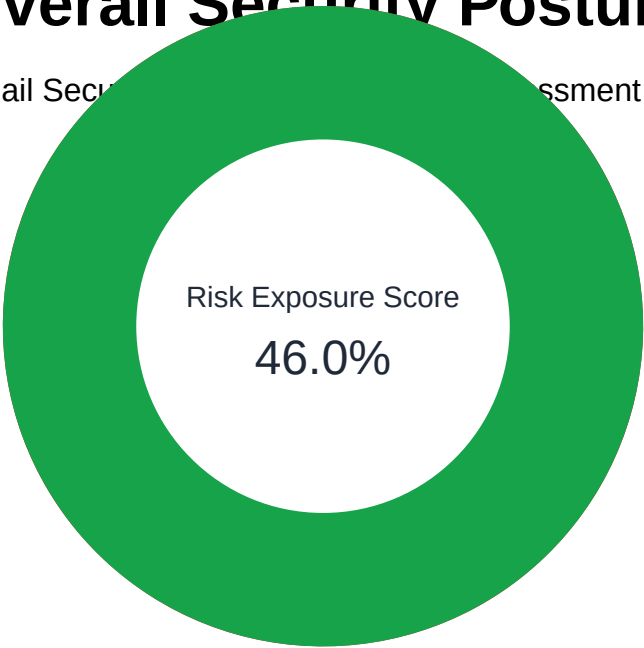


Overall Security Posture

Quick Email Security Assessment summary



% Risk Exposure: 46.0%

% Security Posture: 54.0%

Tenant: contoso.onmicrosoft.com
Assessment ID: sample-email-security-001
Assessment Date: January 15, 2024 at 03:30 PM

Assessment Overview

Total Actionable Controls: 18
Passed Controls: 10
Failed Controls: 5
Partial Controls: 2
Manual Review: 1
Not Applicable: 2
Overall Score: 54/100
Pass Rate: 54.0%
Security Posture: 54.0%
Risk Exposure: 46.0%

Executive Summary

This quick security assessment evaluated 20 controls. 7 controls passed, 8 failed, and 2 were not applicable.

Key Strengths

- Anti-phishing policy exists and enabled (HIGH)
- Mailbox auditing is enabled (MEDIUM)
- POP/IMAP is disabled (MEDIUM)
- DKIM signing enabled (MEDIUM)
- SPF record published (LOW)

Areas for Improvement

- Safe Links policy is enabled (HIGH): Create and enable a Safe Links policy in the Microsoft 365 Defender portal.
- Safe Attachments policy is enabled (CRITICAL): Enable Safe Attachments with a strict detection level for all recipients.
- SMTP AUTH is disabled (HIGH): Block SMTP AUTH and require modern authentication for all clients.
- Transport rules for data loss prevention (HIGH): Create transport rules to block or quarantine emails containing sensitive data.
- DMARC policy configured (MEDIUM): Update DMARC policy to 'quarantine' or 'reject' after monitoring p=None reports.
- Exchange admin roles limited (CRITICAL): Apply least-privilege principle and assign Exchange Administrator role only to required accounts.
- MFA enforced for all users (CRITICAL): Enforce MFA for all users and disable legacy authentication protocols.
- Legacy authentication blocked (HIGH): Block all legacy authentication protocols using Conditional Access.

Control Results

[PASSED] Anti-phishing policy exists and enabled

Category: Anti-Phishing | Severity: HIGH | Score: 100/100

Evidence: Found 3 enabled anti-phishing policies with recommended settings.

[FAILED] Safe Links policy is enabled

Category: Safe Links | Severity: HIGH | Score: 0/100

Evidence: No Safe Links policy was found. Users are not protected against malicious URLs.

Recommendation: Create and enable a Safe Links policy in the Microsoft 365 Defender portal.

[FAILED] Safe Attachments policy is enabled

Category: Safe Attachments | Severity: CRITICAL | Score: 0/100

Evidence: No Safe Attachments policy detected. Malware protection is not applied to emails.

Recommendation: Enable Safe Attachments with a strict detection level for all recipients.

[PARTIAL] Anti-malware policy exists

Category: Anti-Malware | Severity: HIGH | Score: 50/100

Evidence: Anti-malware policy exists but filtering is set to 'Off' for some file types.

Recommendation: Enable malware filtering for all common file types and set action to 'Quarantine'.

[PASSED] Mailbox auditing is enabled

Category: Audit | Severity: MEDIUM | Score: 100/100

Evidence: Mailbox audit logging is enabled for 95% of mailboxes.

[FAILED] SMTP AUTH is disabled

Category: Authentication | Severity: HIGH | Score: 0/100

Evidence: SMTP AUTH is still enabled for legacy clients. This bypasses modern authentication.

Recommendation: Block SMTP AUTH and require modern authentication for all clients.

[PASSED] POP/IMAP is disabled

Category: Protocols | Severity: MEDIUM | Score: 100/100

Evidence: POP3 and IMAP4 are disabled for all users.

[PARTIAL] Anti-spam policy is enforced

Category: Anti-Spam | Severity: MEDIUM | Score: 50/100

Evidence: Anti-spam policy exists but bulk email threshold is set too high.

Recommendation: Lower the bulk email spam threshold and enable safety tips.

[MANUAL_REVIEW] Guest user access reviewed

Category: Access Control | Severity: LOW | Score: 0/100

Evidence: Guest user access settings require manual verification due to external sharing policies.

Recommendation: Review guest user access settings and external sharing policies quarterly.

[FAILED] Transport rules for data loss prevention

Category: DLP | Severity: HIGH | Score: 0/100

Evidence: No transport rules configured for sensitive data types.

Recommendation: Create transport rules to block or quarantine emails containing sensitive data.

[PASSED] DKIM signing enabled

Category: Email Authentication | Severity: MEDIUM | Score: 100/100

Evidence: DKIM is enabled and signing is active for all accepted domains.

[FAILED] DMARC policy configured

Category: Email Authentication | Severity: MEDIUM | Score: 0/100

Evidence: DMARC policy is set to 'none' instead of 'quarantine' or 'reject'.

Recommendation: Update DMARC policy to 'quarantine' or 'reject' after monitoring p=None reports.

[PASSED] SPF record published

Category: Email Authentication | Severity: LOW | Score: 100/100

Evidence: SPF record is published and includes all authorized sending services.

[FAILED] Exchange admin roles limited

Category: Access Control | Severity: CRITICAL | Score: 0/100

Evidence: Too many users have Exchange Administrator role assigned.

Recommendation: Apply least-privilege principle and assign Exchange Administrator role only to required accounts.

[FAILED] MFA enforced for all users

Category: Authentication | Severity: CRITICAL | Score: 0/100

Evidence: MFA is not enforced for all users. 12 users have MFA disabled.

Recommendation: Enforce MFA for all users and disable legacy authentication protocols.

[PARTIAL] Conditional Access policies configured

Category: Access Control | Severity: HIGH | Score: 50/100

Evidence: Conditional Access policies exist but do not cover all risk conditions.

Recommendation: Expand Conditional Access policies to block legacy auth and require compliant devices.

[FAILED] Legacy authentication blocked

Category: Authentication | Severity: HIGH | Score: 0/100

Evidence: Legacy authentication protocols (POP, IMAP, SMTP AUTH) are still enabled.

Recommendation: Block all legacy authentication protocols using Conditional Access.

[PASSED] Password protection policy enabled

Category: Authentication | Severity: MEDIUM | Score: 100/100

Evidence: Password protection policy is enabled with banned password lists.

[NOT_APPLICABLE] Guest user MFA enforced

Category: Access Control | Severity: MEDIUM | Score: 0/100

Evidence: No guest users are present in the tenant.

[PASSED] Message encryption enabled

Category: Encryption | Severity: LOW | Score: 100/100

Evidence: Office 365 Message Encryption is enabled for external recipients.

Recommendations

1. Enable Safe Attachments protection

Severity: CRITICAL

Description: Safe Attachments provides an additional layer of protection against unknown malware.

Remediation: Create a Safe Attachments policy in the Microsoft 365 Defender portal with a strict detection level.

2. Enforce multi-factor authentication

Severity: CRITICAL

Description: MFA significantly reduces the risk of credential-based attacks.

Remediation: Enable MFA for all users and block legacy authentication protocols.

3. Enable Safe Links protection

Severity: HIGH

Description: Safe Links checks URLs in real-time to protect against phishing and malware.

Remediation: Create a Safe Links policy in the Microsoft 365 Defender portal.

4. Limit Exchange Administrator role assignments

Severity: HIGH

Description: Excessive Exchange admin privileges increase the blast radius of a compromise.

Remediation: Review and remove unnecessary Exchange Administrator role assignments.

5. Configure data loss prevention transport rules

Severity: HIGH

Description: Transport rules help prevent sensitive data from leaving the organization.

Remediation: Create transport rules to block or quarantine emails containing sensitive data types.

Informational Controls

Total Mailboxes

Evidence: 2,500 mailboxes detected across all licensed users.

Security Alerts

Evidence: 3 high-severity and 12 medium-severity security alerts were detected in the last 30 days.

Data Collection Issues

safe-links-policy

Type: permission_denied

Error: Insufficient privileges to complete operation.

Description: The service principal lacks SecurityActions.ReadWrite.All permission.

Impact: Safe Links policies could not be enumerated.

anti-phish-policy

Type: command_error

Error: Get-AntiPhishPolicy : The term 'Get-AntiPhishPolicy' is not recognized.

Description: Exchange Online PowerShell module version is outdated.

Impact: Anti-phishing policies may be incomplete.

Conclusion

The assessed environment has moderate security gaps that should be addressed. Prioritize the recommendations in this report to improve the overall security posture.

